

# Security+ SY0-701 Memorization Sheet

Print this and keep it beside you while you study. Security+ is a vocabulary exam: most questions describe a situation and ask for the exact term, control, or next step. Every table here is fair game.

## 01 The exam itself

| FACT                                          | VALUE                                            |
|-----------------------------------------------|--------------------------------------------------|
| Exam code                                     | SY0-701 (Security+)                              |
| Questions                                     | Up to 90, multiple choice plus performance-based |
| Time                                          | 90 minutes                                       |
| Passing score                                 | 750 on a scale of 100 to 900 (about 83%)         |
| 1.0 General Security Concepts                 | 12%                                              |
| 2.0 Threats, Vulnerabilities, and Mitigations | 22%                                              |
| 3.0 Security Architecture                     | 18%                                              |
| 4.0 Security Operations                       | 28%                                              |
| 5.0 Security Program Management and Oversight | 20%                                              |

Read for the qualifier: BEST, MOST likely, FIRST, NEXT, LEAST. Many answers are 'the least disruptive control that fixes the stated problem.'

## 02 Security controls and core concepts

| CONTROL CATEGORY | WHO OR WHAT APPLIES IT         | EXAMPLES                                                              |
|------------------|--------------------------------|-----------------------------------------------------------------------|
| Technical        | Systems and software           | Firewalls, encryption, IDS, ACLs, MFA                                 |
| Managerial       | Policy and oversight           | Risk assessments, security policies, awareness program planning       |
| Operational      | People carrying out procedures | Guards, awareness training delivery, incident response steps, backups |
| Physical         | The building and hardware      | Locks, fences, bollards, badges, cameras, lighting                    |

| CONTROL TYPE | PURPOSE                                            | EXAMPLES                                                     |
|--------------|----------------------------------------------------|--------------------------------------------------------------|
| Preventive   | Stop it before it happens                          | Firewall rule, door lock, least privilege                    |
| Deterrent    | Discourage the attempt                             | Warning signs, visible cameras, login banners                |
| Detective    | Notice it happened                                 | IDS, logs, audits, motion sensors, cameras reviewed later    |
| Corrective   | Undo the damage                                    | Restore from backup, patch after incident, incident response |
| Compensating | Alternative when the ideal control is not possible | Extra monitoring on a system that cannot be patched          |
| Directive    | Tell people what to do                             | Policies, procedures, acceptable use, signage                |

- **CIA: Confidentiality** (encryption, access control), **Integrity** (hashing, signatures, change control), **Availability** (redundancy, backups, **DDoS** protection)
  - **Non-repudiation**: the sender cannot deny sending; digital signatures
- **AAA: Authentication** (who you are), **Authorization** (what you may do), **Accounting** (what you did). Authenticating systems as well as people (certificates, **802.1X**)
  - **Gap analysis**: where you are versus where the framework or policy says you should be

- **Deception:** honeypot (decoy system), honeynet (decoy network), honeyfile (bait document), honeytoken (fake credential or record that alerts when used)

| ZERO TRUST COMPONENT         | PLANE         | JOB                                                                       |
|------------------------------|---------------|---------------------------------------------------------------------------|
| Policy engine                | Control plane | Decides allow or deny for each request                                    |
| Policy administrator         | Control plane | Tells the enforcement point what the engine decided                       |
| Adaptive identity            | Control plane | Authentication strength changes with context (location, device, behavior) |
| Threat scope reduction       | Control plane | Limit what any identity can reach                                         |
| Policy-driven access control | Control plane | Rules, not network location, grant access                                 |
| Policy enforcement point     | Data plane    | Where the allow or deny is applied to traffic                             |
| Implicit trust zones         | Data plane    | Small zones where traffic is allowed after verification                   |
| Subject and system           | Data plane    | The user or device asking, and the resource                               |

### Physical security

- Bollards stop vehicles. Fencing sets the perimeter. Lighting deters and helps cameras
- Access control vestibule (mantrap): two doors, one opens at a time, stops tailgating
- Access badge, security guard, video surveillance
- Sensors: **infrared** (body heat), **pressure** (weight on a floor or mat), **microwave** (motion by reflected waves), **ultrasonic** (motion by sound)

## 03 Change management

- Business process: approval process, ownership, stakeholders, impact analysis, test results, backout plan, maintenance window, standard operating procedure
- Technical implications: allow lists and deny lists, restricted activities, downtime, service and application restarts, legacy applications, dependencies
- Documentation: update diagrams, policies, and procedures. Version control tracks every change and lets you roll back
- Order in a question: request and impact analysis, approval, schedule the window, test, implement with a backout plan ready, document

## 04 Cryptography

| CONCEPT           | DETAIL                                                                                                                                                                                       |
|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Symmetric         | One shared key encrypts and decrypts. Fast, bulk data. <b>AES</b> (128, 192, 256-bit), <b>3DES</b> (legacy), ChaCha20, Blowfish                                                              |
| Asymmetric        | Public key encrypts or verifies, private key decrypts or signs. Slow, used for key exchange and signatures. <b>RSA</b> , <b>ECC</b> (smaller keys, same strength), <b>DSA</b> , <b>ECDSA</b> |
| Key exchange      | Diffie-Hellman and <b>ECDHE</b> agree on a shared key over an open channel. Ephemeral keys give perfect forward secrecy                                                                      |
| Hashing           | One-way fixed-length fingerprint: <b>MD5</b> 128-bit (broken), <b>SHA-1</b> 160-bit (deprecated), <b>SHA-256</b> , <b>SHA-3</b> . <b>HMAC</b> adds a key for authenticity                    |
| Salting           | Random data added to a password before hashing so identical passwords hash differently and rainbow tables fail                                                                               |
| Key stretching    | Make hashing slow on purpose: <b>PBKDF2</b> , bcrypt, scrypt, Argon2                                                                                                                         |
| Digital signature | Hash the message, encrypt the hash with the private key. Proves integrity, authenticity, and non-repudiation                                                                                 |
| Key length        | Longer is stronger; <b>AES-256</b> over <b>AES-128</b> , <b>RSA</b> 2048 minimum, <b>ECC</b> 256 is comparable to <b>RSA</b> 3072                                                            |
| Blockchain        | Open public ledger: chained hashed blocks, tamper-evident, distributed                                                                                                                       |

| CONCEPT              | DETAIL                                                                                             |
|----------------------|----------------------------------------------------------------------------------------------------|
| Transport encryption | TLS 1.2 and 1.3 for web and mail, IPsec for VPNs, SSH for shells. Deprecated: SSL, TLS 1.0 and 1.1 |

  

| ENCRYPTION LEVEL    | WHAT IS PROTECTED                               |
|---------------------|-------------------------------------------------|
| Full-disk           | The whole drive; protects a lost laptop         |
| Partition or volume | One partition or logical volume                 |
| File                | Individual files                                |
| Database            | The whole database                              |
| Record              | Individual fields or rows, such as card numbers |

## Tools and obfuscation

- **TPM:** chip on the motherboard that stores keys and measures boot; used by full-disk encryption
- **HSM:** dedicated hardware appliance or card for key storage and crypto operations at scale
- **KMS:** key management service, usually cloud, for creating, rotating, and controlling keys
- **Secure enclave:** isolated processor area for secrets on phones and laptops
- **Key escrow:** a trusted third party holds a copy of the key for recovery
- **Steganography** hides data inside images or audio. **Tokenization** replaces data with a token mapped in a vault. **Data masking** shows only part (xxxx-1234)

| PKI TERM                   | MEANING                                                                                                |
|----------------------------|--------------------------------------------------------------------------------------------------------|
| Certificate authority (CA) | Issues and signs certificates; the root of trust                                                       |
| Registration authority     | Verifies identity before the CA issues                                                                 |
| CSR                        | Certificate signing request: the public key plus identity sent to the CA                               |
| CRL                        | Certificate revocation list, downloaded periodically; can be stale                                     |
| OCSP                       | Real-time revocation check of one certificate; OCSP stapling has the server include a fresh response   |
| Self-signed                | Not signed by a trusted CA; browsers warn; internal use only                                           |
| Third-party                | Issued by a public CA; trusted by browsers                                                             |
| Wildcard                   | *.example.com covers every subdomain at one level                                                      |
| SAN                        | Subject alternative name: several names on one certificate                                             |
| Formats                    | PEM (Base64 text, .crt .pem), DER (binary), PFX or P12 (with private key), P7B (chain, no private key) |

## 05 Threat actors, vectors, and social engineering

| ACTOR              | TYPICAL TRAITS                                             | TYPICAL MOTIVATION                             |
|--------------------|------------------------------------------------------------|------------------------------------------------|
| Nation-state       | External, well funded, highly sophisticated, patient (APT) | Espionage, war, disruption                     |
| Organized crime    | External, funded, sophisticated                            | Financial gain: ransomware, fraud              |
| Hacktivist         | External, modest resources                                 | Philosophical or political, service disruption |
| Insider threat     | Internal, has access already                               | Revenge, financial gain, or accidental         |
| Unskilled attacker | External, low sophistication, uses others' tools           | Chaos, notoriety                               |
| Shadow IT          | Internal, not malicious                                    | Convenience; creates unmanaged risk            |

## Motivations to recognize

- Data exfiltration, espionage, service disruption, blackmail, financial gain, philosophical or political beliefs, ethical (white hat), revenge, disruption or chaos, war

| VECTOR                                  | EXAMPLES                                           |
|-----------------------------------------|----------------------------------------------------|
| Message-based                           | Email, <b>SMS</b> , instant messaging              |
| Image-based and file-based              | Malicious images, macros in documents, executables |
| Voice call                              | Vishing                                            |
| Removable device                        | <b>USB</b> drops                                   |
| Vulnerable software                     | Client-based (agent installed) versus agentless    |
| Unsupported systems                     | End-of-life operating systems and applications     |
| Insecure networks                       | Open wireless, unmanaged wired ports, Bluetooth    |
| Open service ports, default credentials | Exposed services, unchanged admin passwords        |
| Supply chain                            | Managed service providers, vendors, suppliers      |

| HUMAN VECTOR                                  | ONE-LINE DEFINITION                                                    |
|-----------------------------------------------|------------------------------------------------------------------------|
| Phishing                                      | Fraudulent email to steal credentials or deliver malware               |
| Vishing, smishing                             | The same by voice call, by text message                                |
| Spear phishing, whaling                       | Targeted at a person; targeted at an executive                         |
| Business email compromise                     | Attacker uses or imitates a real business account to redirect payments |
| Pretexting                                    | An invented story that justifies the request                           |
| Impersonation, brand impersonation            | Pretending to be a person; pretending to be a company                  |
| Watering hole                                 | Compromise a site the targets already visit                            |
| Typosquatting                                 | Look-alike domain names catching mistyped <b>URLs</b>                  |
| Misinformation, disinformation                | False content spread unknowingly; spread deliberately                  |
| Tailgating, shoulder surfing, dumpster diving | Following through a door; watching a screen; reading the trash         |

## 06 Vulnerabilities

| CLASS            | MEMBERS TO RECOGNIZE                                                                                   |
|------------------|--------------------------------------------------------------------------------------------------------|
| Application      | Memory injection, buffer overflow, race conditions (time-of-check to time-of-use), malicious update    |
| Operating system | Unpatched services, weak defaults                                                                      |
| Web-based        | <b>SQL</b> injection (' OR 1=1), cross-site scripting (script in a page other users load)              |
| Hardware         | Firmware flaws, end-of-life, legacy devices                                                            |
| Virtualization   | <b>VM</b> escape (guest reaches the host), resource reuse (data left in reallocated memory or storage) |
| Cloud-specific   | Misconfigured storage, shared-tenant risks, exposed <b>APIs</b>                                        |
| Supply chain     | Service provider, hardware provider, software provider                                                 |
| Cryptographic    | Weak or deprecated algorithms, short keys, bad implementations                                         |
| Misconfiguration | Open ports, default settings, excessive permissions                                                    |

| CLASS    | MEMBERS TO RECOGNIZE                                                |
|----------|---------------------------------------------------------------------|
| Mobile   | Side loading (apps from outside the store), jailbreaking or rooting |
| Zero-day | Known to attackers before a patch exists                            |

## 07 Attacks and indicators

| MALWARE                                           | TELL                                                                                            |                                           |
|---------------------------------------------------|-------------------------------------------------------------------------------------------------|-------------------------------------------|
| Ransomware                                        | Files encrypted, payment demanded                                                               |                                           |
| Trojan                                            | Hidden inside a wanted program; remote access trojan gives control                              |                                           |
| Worm                                              | Spreads by itself across the network                                                            |                                           |
| Virus                                             | Attaches to files, needs a user action to spread                                                |                                           |
| Spyware, keylogger                                | Watches activity; records keystrokes                                                            |                                           |
| Bloatware                                         | Unwanted preinstalled software, expands attack surface                                          |                                           |
| Logic bomb                                        | Triggers on a date or event                                                                     |                                           |
| Rootkit                                           | Hides at kernel or firmware level; survives reboots, evades antivirus                           |                                           |
| ATTACK                                            | TELL                                                                                            | DEFENSE                                   |
| DDoS (amplified, reflected)                       | Floods from many sources; small requests to third parties produce large responses at the victim | Upstream scrubbing, rate limiting         |
| DNS attacks                                       | Poisoned cache, spoofed answers, domain hijacking                                               | DNSSEC, DNS filtering                     |
| Wireless attacks                                  | Evil twin, deauthentication, rogue AP                                                           | WPA3, 802.1X, protected management frames |
| On-path                                           | Attacker between the parties reads or alters traffic                                            | TLS, VPN, certificate pinning             |
| Credential replay                                 | Captured authentication reused                                                                  | Session tokens, nonces, MFA               |
| Injection                                         | Untrusted input executed by a database, shell, or LDAP                                          | Input validation, parameterized queries   |
| Buffer overflow                                   | Input longer than the buffer overwrites memory                                                  | Patching, memory-safe code, ASLR          |
| Privilege escalation                              | Normal user gains admin                                                                         | Least privilege, patching                 |
| Forgery (CSRF, SSRF)                              | Victim's browser or the server is tricked into making a request                                 | Anti-forgery tokens, input validation     |
| Directory traversal                               | ../ in a path reaches files outside the web root                                                | Input validation, least privilege         |
| Downgrade                                         | Forces a weaker protocol or cipher                                                              | Disable legacy protocols                  |
| Collision, birthday                               | Two inputs with the same hash; probability grows fast with attempts                             | Strong hashes (SHA-256+)                  |
| Password spraying                                 | One common password tried against many accounts                                                 | MFA, lockout tuned for spraying           |
| Brute force                                       | Every combination against one account                                                           | Lockout, length, MFA                      |
| RFID cloning, brute force on locks, environmental | Physical attacks                                                                                | Physical controls, monitoring             |

### Indicators of malicious activity

- Account lockout, concurrent session usage, impossible travel (logins from two distant places in minutes)
- Blocked content, resource consumption spikes, resources becoming inaccessible

- Out-of-cycle logging, missing logs (attacker cleared them), published or documented exploits for your versions

Mitigation techniques

- Segmentation; access control (**ACLs**, permissions); application allow lists; isolation; patching; encryption; monitoring; least privilege; configuration enforcement; decommissioning
- Hardening: encryption, endpoint protection, host-based firewall, host-based **IPS**, disable unused ports and protocols, change default passwords, remove unnecessary software

08 Security architecture

Architecture models

- Cloud **responsibility matrix**: the provider secures the infrastructure; the customer secures data, identities, and configuration. Hybrid and third-party vendors add shared responsibility
- **Infrastructure as code**: environments defined in files; **serverless**: provider runs the function; **microservices**: many small services with **APIs**
- Network: **physical isolation (air gap)**, **logical segmentation (VLANs, subnets)**, **software-defined networking**
- On-premises versus cloud; centralized versus decentralized; **containerization** (shared kernel) versus **virtualization** (hypervisor)
- **IoT, ICS/SCADA** (industrial control), **RTOS** (real-time), **embedded** systems: hard to patch, isolate them
- Considerations: availability, resilience, cost, responsiveness, scalability, ease of deployment, risk transference, ease of recovery, patch availability, inability to patch, power, compute

| INFRASTRUCTURE<br>CONCEPT    | DETAIL                                                                                                                                                                              |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Security zones               | Trusted, untrusted, screened subnet ( <b>DMZ</b> ) for public-facing servers                                                                                                        |
| Attack surface               | Everything reachable; shrink it                                                                                                                                                     |
| Fail-open versus fail-closed | Fail-open keeps traffic flowing when the control fails (availability); fail-closed blocks (security)                                                                                |
| Active versus passive        | Inline (can block, can bottleneck) versus tap or monitor port (sees a copy, alerts only)                                                                                            |
| Jump server                  | Hardened host you go through to reach protected systems                                                                                                                             |
| Proxy server                 | Forward proxy for clients; reverse proxy in front of servers                                                                                                                        |
| IPS versus IDS               | Inline and blocks versus out of band and alerts                                                                                                                                     |
| Load balancer                | Spreads traffic; active-active or active-passive                                                                                                                                    |
| Sensors                      | Collect traffic or logs for monitoring                                                                                                                                              |
| Port security                | <b>802.1X</b> authentication on switch ports and <b>Wi-Fi</b> , using <b>EAP</b> ( <b>EAP-TLS</b> with certificates is strongest; <b>PEAP</b> , <b>EAP-TTLS</b> , <b>EAP-FAST</b> ) |
| Firewall types               | <b>WAF</b> (Layer 7, protects web apps), <b>UTM</b> (all-in-one), <b>NGFW</b> (application-aware, user-aware), Layer 4 (ports) versus Layer 7 (content)                             |
| Secure communication         | <b>VPN</b> and remote access; tunneling with <b>TLS</b> or <b>IPsec</b> ; <b>SD-WAN</b> ; <b>SASE</b> (network plus cloud security)                                                 |

09 Data protection

| DATA TYPE                           | MEANING                                                           |
|-------------------------------------|-------------------------------------------------------------------|
| Regulated                           | Law or regulation governs it: health, payment card, personal data |
| Trade secret, intellectual property | Formulas, source code, designs                                    |

| DATA TYPE                                | MEANING                                       |
|------------------------------------------|-----------------------------------------------|
| Legal information, financial information | Contracts, litigation; ledgers, filings       |
| Human-readable versus non-human-readable | Documents versus binaries and encrypted blobs |

  

| CLASSIFICATION     | TYPICAL USE                                 |
|--------------------|---------------------------------------------|
| Public             | Anyone may see it                           |
| Private, sensitive | Internal; harm if leaked                    |
| Confidential       | Limited to those who need it                |
| Restricted         | Tightly controlled, often regulated         |
| Critical           | The organization cannot function without it |

  

|                                                                                                                                                                 |                                                                                                                                                                                                                                                                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>States: <b>at rest</b> (disk, database), <b>in transit</b> (network), <b>in use</b> (memory, being processed)</li> </ul> | <ul style="list-style-type: none"> <li><b>Data sovereignty:</b> data is subject to the laws of the country where it is stored. <b>Geolocation</b> and <b>geographic restrictions</b> control where data may live or be accessed from</li> <li>Methods: encryption, hashing, masking, tokenization, obfuscation, segmentation, permission restrictions</li> </ul> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## 10 Resilience and recovery

| CONCEPT                          | DETAIL                                                                                                                            |
|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Load balancing versus clustering | Spreads requests across servers; servers act as one system with failover                                                          |
| Hot site                         | Running mirror, minutes to switch, most expensive                                                                                 |
| Warm site                        | Equipment ready, data restored on failover, hours                                                                                 |
| Cold site                        | Space and power only, days                                                                                                        |
| Geographic dispersion            | Sites far enough apart that one disaster cannot hit both                                                                          |
| Platform diversity, multi-cloud  | Different vendors so one flaw or outage does not take everything                                                                  |
| Continuity of operations         | Keep the business running through the incident                                                                                    |
| Capacity planning                | People, technology, infrastructure sized for growth and surge                                                                     |
| Testing                          | Tabletop (talk through), failover (actually switch), simulation (drill), parallel processing (run both and compare)               |
| Backups                          | Onsite and offsite, frequency, encryption, snapshots, replication, journaling (log every change), tested recovery                 |
| Full, incremental, differential  | Everything; changes since the last backup of any kind (small, slow restore); changes since the last full (bigger, faster restore) |
| Power                            | UPS bridges to the generator; generator for long outages                                                                          |

  

| RAID    | HOW IT WORKS                               | SURVIVES            |
|---------|--------------------------------------------|---------------------|
| RAID 0  | Striping, no redundancy                    | Nothing; speed only |
| RAID 1  | Mirroring                                  | One disk failure    |
| RAID 5  | Striping with distributed parity, 3+ disks | One disk            |
| RAID 6  | Striping with double parity, 4+ disks      | Two disks           |
| RAID 10 | Mirrored pairs, striped                    | One disk per mirror |

## 11 Securing resources and monitoring

### Baselines, hardening, wireless, mobile, applications

- Secure baseline: **establish** it, **deploy** it, **maintain** it (drift detection)
- Hardening targets: mobile devices, workstations, switches, routers, cloud infrastructure, servers, **ICS/SCADA**, embedded and **RTOS**, **IoT**
- Wireless: site survey and heat map first; **WPA3**; enterprise authentication with **AAA** and **RADIUS**; **EAP-TLS** strongest
- Mobile: **MDM** enforces policy; deployment models **BYOD** (personal), **COPE** (company owned, personally enabled), **CYOD** (choose from a list); connections cellular, **Wi-Fi**, Bluetooth
- Application security: input validation, secure cookies, static code analysis, code signing; **sandboxing** runs untrusted code in isolation

### Asset management

- Acquisition and procurement, assignment and ownership, classification, monitoring and asset tracking (inventory, enumeration)
- Disposal: **sanitization** (wipe so data cannot be recovered), **destruction** (shred, degauss, pulverize), **certification** (proof it was done), **data retention** rules first

| VULNERABILITY MANAGEMENT STEP | CONTENTS                                                                                                                                                                                                                                                              |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Identification                | Vulnerability scans (credentialed sees more), application analysis static and dynamic, package monitoring, threat feeds ( <b>OSINT</b> , proprietary, <b>ISACs</b> , dark web), penetration testing, responsible disclosure and bug bounty, system and process audits |
| Analysis                      | Confirm (false positive, false negative), prioritize with <b>CVSS</b> and <b>CVE</b> , classification, exposure factor, environmental variables, industry and organizational impact, risk tolerance                                                                   |
| Response                      | Patch, cyber insurance, segmentation, compensating controls, documented exceptions and exemptions                                                                                                                                                                     |
| Validation                    | Rescan, audit, verify                                                                                                                                                                                                                                                 |
| Reporting                     | Trends, open items, time to remediate                                                                                                                                                                                                                                 |

| CVSS RATING | SCORE       |
|-------------|-------------|
| None        | 0.0         |
| Low         | 0.1 to 3.9  |
| Medium      | 4.0 to 6.9  |
| High        | 7.0 to 8.9  |
| Critical    | 9.0 to 10.0 |

### Monitoring tools

- Log aggregation, alerting, scanning, reporting, archiving; alert response and remediation (quarantine); alert tuning to cut false positives
- SCAP**: automated compliance checking against benchmarks (**CIS**). Agents versus agentless collection
- SIEM** correlates logs; **antivirus**; **DLP** stops data leaving; **SNMP traps** push device alerts; **NetFlow** shows who talked to whom; **vulnerability scanners**

| ENTERPRISE CAPABILITY                                               | ONE-LINE JOB                                                                                           |
|---------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Firewall rules, access lists, ports and protocols, screened subnets | Allow only what is needed between zones                                                                |
| IDS/IPS trends and signatures                                       | Detect known patterns; tune for trends                                                                 |
| Web filter                                                          | Agent-based or centralized proxy; <b>URL</b> scanning, content categorization, block rules, reputation |



| ENTERPRISE CAPABILITY     | ONE-LINE JOB                                                                                                                                                      |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Operating system security | Group Policy on Windows, SELinux on Linux                                                                                                                         |
| Secure protocols          | Pick the encrypted port and transport: <b>SSH</b> not Telnet, <b>HTTPS</b> not HTTP, <b>SFTP</b> not FTP, <b>SNMPv3</b> , <b>LDAPS</b> , <b>DoH</b> or <b>DoT</b> |
| DNS filtering             | Block known-bad domains at resolution                                                                                                                             |
| Email security            | <b>SPF</b> (allowed senders), <b>DKIM</b> (signed mail), <b>DMARC</b> (policy for failures), email gateway                                                        |
| File integrity monitoring | Alert when critical files change                                                                                                                                  |
| DLP                       | Prevent sensitive data from leaving by email, <b>USB</b> , or upload                                                                                              |
| NAC                       | Check device health before granting network access                                                                                                                |
| EDR and XDR               | Endpoint detection and response; extended across network and cloud                                                                                                |
| User behavior analytics   | Baseline each user, alert on deviation                                                                                                                            |

## 12 Identity and access management

| CONCEPT                         | DETAIL                                                                                                                                                                                                 |
|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Provisioning and deprovisioning | Create access on hire, remove it on exit; the classic offboarding failure is a still-active account                                                                                                    |
| Identity proofing               | Verify a person is who they claim before issuing credentials                                                                                                                                           |
| Federation                      | One organization trusts another's identities                                                                                                                                                           |
| SSO protocols                   | <b>SAML</b> (XML, enterprise web <b>SSO</b> ), <b>OAuth</b> (authorization delegation), OpenID Connect (authentication on <b>OAuth</b> ), <b>LDAP</b> (directory), Kerberos (tickets, Windows domains) |
| Attestation                     | Confirming that a device or account state is what it claims                                                                                                                                            |

| ACCESS CONTROL MODEL     | RULE                                                                        |
|--------------------------|-----------------------------------------------------------------------------|
| Mandatory (MAC)          | Labels and clearances set by the system; users cannot change them; military |
| Discretionary (DAC)      | The owner decides who gets access; file permissions                         |
| Role-based (RBAC)        | Permissions attach to roles, users to roles                                 |
| Rule-based               | Fixed rules such as firewall <b>ACLs</b> or time limits                     |
| Attribute-based (ABAC)   | Decisions from attributes: department, location, device, time               |
| Time-of-day restrictions | Access only during set hours                                                |
| Least privilege          | Only what the job needs                                                     |

### MFA and passwords

- Factors: **something you know** (password, **PIN**), **something you have** (token, phone, smart card, security key), **something you are** (biometrics), **somewhere you are** (location)
- Tokens: hard (device), soft (app), security keys (**FIDO2**). Biometrics have false acceptance and false rejection rates
- Password policy: length beats complexity, no reuse, expiration and age rules, password managers, **passwordless** with keys or biometrics
- Privileged access management**: just-in-time permissions, password vaulting, ephemeral (temporary) credentials

Automation and orchestration

- Use cases: user and resource provisioning, guard rails, security groups, ticket creation and escalation, enabling and disabling services, continuous integration and testing, integrations and **APIs**
- Benefits: efficiency, enforced baselines, secure scaling, employee retention, reaction time, workforce multiplier
- Considerations: complexity, cost, single point of failure, technical debt, ongoing supportability

13 Incident response and forensics

Incident response process, in order

- 1. Preparation: plans, tools, training, contacts.
- 2. Detection: notice that something happened.
- 3. Analysis: confirm and scope it.
- 4. Containment: stop the spread (isolate, block).
- 5. Eradication: remove the cause (malware, accounts, vulnerability).
- 6. Recovery: restore systems and monitor.
- 7. Lessons learned: review and improve.
- Training and testing: tabletop exercises and simulations
- **Root cause analysis** finds why, not just what. **Threat hunting** searches proactively for signs an alert missed
- Forensics: **legal hold** (preserve, do not delete), **chain of custody** (who handled evidence, when), **acquisition** (image it), **preservation, reporting, e-discovery**
- Order of volatility (collect first): **CPU** cache and registers, **RAM**, swap and temporary files, disk, remote logs, archives and backups

| DATA SOURCE                                                         | WHAT IT TELLS YOU                              |
|---------------------------------------------------------------------|------------------------------------------------|
| Firewall logs                                                       | Allowed and blocked connections                |
| Application logs                                                    | Errors, logins, transactions                   |
| Endpoint logs                                                       | Processes, files, <b>EDR</b> alerts            |
| OS-specific logs                                                    | Windows Event logs, Linux syslog and auth logs |
| IPS/IDS logs                                                        | Matched signatures                             |
| Network logs, metadata                                              | Flows, <b>DNS</b> , headers                    |
| Vulnerability scans, automated reports, dashboards, packet captures | State, trends, and raw evidence                |

14 Governance, risk, and compliance

| DOCUMENT  | WHAT IT IS                    | EXAMPLES                                                                                                                         |
|-----------|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| Policy    | What must be done, high level | Acceptable use, information security, business continuity, disaster recovery, incident response, <b>SDLC</b> , change management |
| Standard  | Specific mandatory settings   | Password, access control, physical security, encryption                                                                          |
| Procedure | Step by step how              | Change management steps, onboarding and offboarding, playbooks                                                                   |
| Guideline | Recommended, not mandatory    | Best-practice advice                                                                                                             |

- External considerations: regulatory, legal, industry, local and regional, national, global. Monitoring and revision keep documents current
- Governance structures: boards, committees, government entities; centralized versus decentralized

- Data roles: **owner** (accountable), **controller** (decides why and how personal data is processed), **processor** (processes on the controller's behalf), **custodian or steward** (day-to-day handling and quality)

| RISK TERM                           | DEFINITION OR FORMULA                                                                                                                  |
|-------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Asset value (AV)                    | What the asset is worth                                                                                                                |
| Exposure factor (EF)                | Fraction of value lost in one incident                                                                                                 |
| Single loss expectancy              | $SLE = AV \times EF$                                                                                                                   |
| Annualized rate of occurrence (ARO) | How many times per year                                                                                                                |
| Annualized loss expectancy          | $ALE = SLE \times ARO$                                                                                                                 |
| Qualitative versus quantitative     | High/medium/low ratings versus dollars and probabilities                                                                               |
| Assessment cadence                  | Ad hoc, recurring, one-time, continuous                                                                                                |
| Risk register                       | List of risks with key risk indicators, owners, and thresholds                                                                         |
| Risk tolerance and appetite         | How much variance is acceptable; appetite is expansionary, conservative, or neutral                                                    |
| Strategies                          | Transfer (insurance), accept (with exemption or exception), avoid (stop the activity), mitigate (add controls)                         |
| Business impact analysis            | <b>RTO</b> (time to restore), <b>RPO</b> (data loss allowed), <b>MTTR</b> (mean repair time), <b>MTBF</b> (mean time between failures) |

| AGREEMENT | USE                                                                 |
|-----------|---------------------------------------------------------------------|
| SLA       | Measurable service levels and penalties                             |
| MOA, MOU  | Agreement of intent; <b>MOU</b> less formal                         |
| MSA       | Master agreement covering the relationship; work orders hang off it |
| WO / SOW  | Work order or statement of work for one job                         |
| NDA       | Confidentiality                                                     |
| BPA       | Business partnership agreement: profits, responsibilities           |

### Third-party risk

- Vendor assessment: penetration testing, right-to-audit clause, evidence of internal audits, independent assessments, supply chain analysis
- Vendor selection: due diligence, conflict of interest. Ongoing: monitoring, questionnaires, rules of engagement

### Compliance and privacy

- Reporting: internal and external. Consequences: fines, sanctions, reputational damage, loss of license, contractual impacts
- Monitoring: due diligence and due care, attestation and acknowledgement, internal and external, automation
- Privacy: legal implications at local, regional, national, global levels; data subject; controller versus processor; ownership; data inventory and retention; right to be forgotten

### Audits, assessments, penetration testing

- Attestation; internal (compliance, audit committee, self-assessments); external (regulatory, examinations, assessment, independent third-party audit)
- Pen test types: physical, offensive (red), defensive (blue), integrated (purple)
- Environment knowledge: **known** (full information, white box), **partially known** (some, gray box), **unknown** (none, black box)
- Reconnaissance: **passive** (public sources, no contact) versus **active** (scanning the target)

## Security awareness

- Phishing campaigns and recognizing and reporting attempts; anomalous behavior recognition (risky, unexpected, unintentional)
- User guidance: policies and handbooks, situational awareness, insider threat, password management, removable media and cables, social engineering, operational security, hybrid and remote work
- Reporting and monitoring: initial and recurring; program development and execution

## 15 Ports and secure protocol pairs

| INSECURE     | PORT     | SECURE REPLACEMENT                            | PORT         |
|--------------|----------|-----------------------------------------------|--------------|
| HTTP         | 80       | HTTPS (TLS)                                   | 443          |
| FTP          | 20, 21   | SFTP (over SSH); FTPS                         | 22; 989, 990 |
| Telnet       | 23       | SSH                                           | 22           |
| SMTP         | 25       | SMTPS or submission with TLS                  | 465, 587     |
| POP3         | 110      | POP3S                                         | 995          |
| IMAP         | 143      | IMAPS                                         | 993          |
| LDAP         | 389      | LDAPS                                         | 636          |
| SNMP v1, v2c | 161, 162 | SNMPv3 (same ports, adds auth and encryption) | 161, 162     |
| DNS          | 53       | DNS over TLS; DNS over HTTPS                  | 853; 443     |
| NTP          | 123      | NTS                                           | 123          |
| RTP (voice)  | dynamic  | SRTP                                          | dynamic      |
| SIP          | 5060     | SIP over TLS                                  | 5061         |

- Other ports: **DHCP** 67/68, **TFTP** 69, Kerberos 88, **RDP** 3389, **SMB** 445, syslog 514, **RADIUS** 1812/1813, **TACACS+** TCP 49, **SQL Server** 1433, MySQL 3306, **IKE** 500 and **NAT-T** 4500
- **IPsec**: **AH** integrity only, **ESP** encryption, **IKE** negotiates keys; transport mode protects the payload, tunnel mode wraps the whole packet
- Email authentication: **SPF** lists allowed sending servers, **DKIM** signs messages, **DMARC** says what to do when they fail
- Wireless: **WEP** broken, **WPA** deprecated, **WPA2 AES**, **WPA3 SAE**; enterprise mode uses **802.1X** with **RADIUS**

## 16 Acronyms

Every acronym used in this course, 206 in all. In lessons and on this sheet, hover over an acronym for the short version; click it, or click one below, for the longer explanation.

| ACRONYM        | STANDS FOR                                    | MEANING                                                                                                       |
|----------------|-----------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>3DES</b>    | Triple Data Encryption Standard               | DES applied three times; legacy and slow, replaced by AES.                                                    |
| <b>802.1X</b>  | IEEE 802.1X                                   | Port-based network access control: a device must authenticate before the switch port or Wi-Fi passes traffic. |
| <b>AAA</b>     | Authentication, authorization, and accounting | Prove who you are, decide what you may do, record what you did.                                               |
| <b>ABAC</b>    | Attribute-based access control                | Access decisions based on attributes of the user, resource, and context, such as time and location.           |
| <b>ACL</b>     | Access control list                           | An ordered list of permit and deny rules on a router, firewall, or file system.                               |
| <b>AES</b>     | Advanced Encryption Standard                  | The standard symmetric cipher, with 128, 192, or 256-bit keys.                                                |
| <b>AES-128</b> | AES with a 128-bit key                        | The standard-strength AES, secure and fast.                                                                   |
| <b>AES-256</b> | AES with a 256-bit key                        | The high-strength AES used for data at rest and sensitive sessions.                                           |

| ACRONYM         | STANDS FOR                                                      | MEANING                                                                                                            |
|-----------------|-----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| <b>AES-CCMP</b> | AES in CCMP mode                                                | The AES-based encryption WPA2 uses for Wi-Fi.                                                                      |
| <b>AH</b>       | Authentication Header                                           | The IPsec protocol that provides integrity and authentication without encryption.                                  |
| <b>ALE</b>      | Annualized loss expectancy                                      | The expected yearly cost of a risk: SLE times ARO.                                                                 |
| <b>AP</b>       | Access point                                                    | The radio that bridges Wi-Fi clients onto the wired network.                                                       |
| <b>API</b>      | Application programming interface                               | The defined way one program talks to another, such as the web endpoints a cloud service exposes.                   |
| <b>APT</b>      | Advanced persistent threat                                      | A well-funded, skilled, patient attacker, usually a nation-state, that stays hidden for a long time.               |
| <b>ARO</b>      | Annualized rate of occurrence                                   | How many times per year an incident is expected to happen.                                                         |
| <b>ARP</b>      | Address Resolution Protocol                                     | Finds the MAC address that goes with a known IPv4 address on the local segment.                                    |
| <b>ASLR</b>     | Address space layout randomization                              | Randomizes where programs load in memory so exploits cannot predict addresses.                                     |
| <b>AUP</b>      | Acceptable use policy                                           | The rules for how staff may use company systems and data.                                                          |
| <b>AV</b>       | Asset value, or antivirus                                       | In risk math, what an asset is worth; in endpoint security, antivirus software.                                    |
| <b>BEC</b>      | Business email compromise                                       | Fraud by email impersonating an executive or vendor to redirect payments.                                          |
| <b>BIA</b>      | Business impact analysis                                        | Identifies critical functions and what an outage of each would cost, setting RTO and RPO.                          |
| <b>BPA</b>      | Business partnership agreement                                  | How partners share responsibilities, profits, and liabilities.                                                     |
| <b>BYOD</b>     | Bring your own device                                           | Staff use personal phones and laptops for work.                                                                    |
| <b>CA</b>       | Certificate authority                                           | The trusted entity that signs certificates.                                                                        |
| <b>CEO</b>      | Chief executive officer                                         | The top executive; the person impersonated in whaling and business email compromise.                               |
| <b>CFO</b>      | Chief financial officer                                         | The executive in charge of money; a common target and impersonation in payment fraud.                              |
| <b>CI</b>       | Continuous integration                                          | Every code change is automatically built and tested when it is committed.                                          |
| <b>CIA</b>      | Confidentiality, integrity, and availability                    | The three goals of security: keep data secret, keep it correct, keep it reachable.                                 |
| <b>CIS</b>      | Center for Internet Security                                    | The organization that publishes hardening benchmarks and the CIS Controls.                                         |
| <b>COPE</b>     | Corporate-owned, personally enabled                             | The company buys the device and lets staff use it personally.                                                      |
| <b>CPU</b>      | Central processing unit                                         | The processor that executes instructions.                                                                          |
| <b>CRL</b>      | Certificate revocation list                                     | A signed list of revoked certificate serial numbers published by a CA.                                             |
| <b>CSR</b>      | Certificate signing request                                     | The file containing a public key and identity that you send to a CA to get a certificate.                          |
| <b>CSRF</b>     | Cross-site request forgery                                      | Tricks a logged-in user's browser into sending a request the user did not intend.                                  |
| <b>CVE</b>      | Common Vulnerabilities and Exposures                            | The public identifier for a known vulnerability, such as CVE-2024-12345.                                           |
| <b>CVSS</b>     | Common Vulnerability Scoring System                             | A 0 to 10 severity score for a vulnerability.                                                                      |
| <b>CYOD</b>     | Choose your own device                                          | Staff pick from a list of approved devices the company then owns and manages.                                      |
| <b>DAC</b>      | Discretionary access control                                    | The owner of a resource decides who may access it.                                                                 |
| <b>DBA</b>      | Database administrator                                          | The person who runs the database servers.                                                                          |
| <b>DDoS</b>     | Distributed denial of service                                   | Many sources, usually a botnet, flood a target at once.                                                            |
| <b>DER</b>      | Distinguished Encoding Rules                                    | The binary format for certificates and keys.                                                                       |
| <b>DES</b>      | Data Encryption Standard                                        | The 1970s 56-bit block cipher; broken by brute force, do not use.                                                  |
| <b>DHCP</b>     | Dynamic Host Configuration Protocol                             | Hands out IP addresses, masks, gateways, and DNS servers automatically (UDP 67 and 68).                            |
| <b>DKIM</b>     | DomainKeys Identified Mail                                      | Outgoing mail is digitally signed; the public key is published in DNS.                                             |
| <b>DLP</b>      | Data loss prevention                                            | Tools that detect and block sensitive data leaving by email, web, USB, or cloud.                                   |
| <b>DMARC</b>    | Domain-based Message Authentication, Reporting, and Conformance | A DNS policy telling receivers what to do with mail that fails SPF or DKIM, and where to send reports.             |
| <b>DMZ</b>      | Demilitarized zone                                              | A screened subnet between the internet and the internal network for public-facing servers.                         |
| <b>DNS</b>      | Domain Name System                                              | Translates names such as www.example.com into IP addresses (UDP 53, TCP 53 for zone transfers).                    |
| <b>DNSSEC</b>   | DNS Security Extensions                                         | Digital signatures on DNS records so a resolver can tell an answer was not forged.                                 |
| <b>DoH</b>      | DNS over HTTPS                                                  | DNS queries carried inside HTTPS on TCP 443 so they cannot be read or altered in transit.                          |
| <b>DoS</b>      | Denial of service                                               | One source floods or crashes a target so it cannot serve users.                                                    |
| <b>DoT</b>      | DNS over TLS                                                    | DNS queries encrypted with TLS on TCP 853.                                                                         |
| <b>DSA</b>      | Digital Signature Algorithm                                     | A government-standard signature algorithm; used less than RSA and ECDSA today.                                     |
| <b>EAP</b>      | Extensible Authentication Protocol                              | The framework that carries authentication methods inside 802.1X.                                                   |
| <b>EAP-FAST</b> | EAP Flexible Authentication via Secure Tunneling                | Cisco's tunneled EAP method using a protected access credential instead of a certificate.                          |
| <b>EAP-TLS</b>  | EAP with Transport Layer Security                               | Certificate-based authentication on both sides; the strongest Wi-Fi and wired 802.1X method.                       |
| <b>EAP-TTLS</b> | EAP with Tunneled TLS                                           | A server certificate builds a TLS tunnel, then the client authenticates inside it with a password or other method. |
| <b>ECC</b>      | Elliptic curve cryptography                                     | Public-key cryptography that gives RSA-level strength with much shorter keys, ideal for phones and IoT.            |
| <b>ECDHE</b>    | Elliptic Curve Diffie-Hellman Ephemeral                         | Key exchange with a fresh elliptic curve key per session, giving forward secrecy.                                  |

| ACRONYM      | STANDS FOR                                                | MEANING                                                                                                             |
|--------------|-----------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| <b>ECDSA</b> | Elliptic Curve Digital Signature Algorithm                | Digital signatures using elliptic curve keys.                                                                       |
| <b>EDR</b>   | Endpoint detection and response                           | Endpoint agents that record activity, detect attacks, and let responders isolate and clean the machine.             |
| <b>EF</b>    | Exposure factor                                           | The fraction of an asset's value lost in one incident.                                                              |
| <b>ESP</b>   | Encapsulating Security Payload                            | The IPsec protocol that encrypts and authenticates the payload.                                                     |
| <b>FIDO2</b> | Fast Identity Online 2                                    | Passwordless or second-factor authentication with a hardware security key or device biometrics.                     |
| <b>FIM</b>   | File integrity monitoring                                 | Alerts when critical files or configurations change.                                                                |
| <b>FTP</b>   | File Transfer Protocol                                    | Plaintext file transfer on TCP 21 (control) and 20 (data); replace with SFTP or FTPS.                               |
| <b>FTPS</b>  | FTP Secure                                                | FTP wrapped in TLS, ports 990 and 989 (implicit) or 21 with an upgrade (explicit).                                  |
| <b>GB</b>    | Gigabyte                                                  | About a billion bytes; the unit for RAM, storage, and data caps.                                                    |
| <b>GCMP</b>  | Galois/Counter Mode Protocol                              | The stronger AES encryption mode used by WPA3.                                                                      |
| <b>GPS</b>   | Global Positioning System                                 | Satellite positioning, also used as a stratum 0 time reference.                                                     |
| <b>HMAC</b>  | Hash-based message authentication code                    | A keyed hash that proves a message came from someone with the key and was not altered.                              |
| <b>HR</b>    | Human resources                                           | The department that hires and separates staff; its system should drive account provisioning and removal.            |
| <b>HSM</b>   | Hardware security module                                  | A tamper-resistant appliance or card that generates, stores, and uses cryptographic keys.                           |
| <b>HTTP</b>  | Hypertext Transfer Protocol                               | Web traffic in the clear on TCP 80.                                                                                 |
| <b>HTTPS</b> | Hypertext Transfer Protocol Secure                        | HTTP inside TLS on TCP 443.                                                                                         |
| <b>IaaS</b>  | Infrastructure as a service                               | The provider supplies virtual machines, storage, and networks; you manage the operating system and up.              |
| <b>IaC</b>   | Infrastructure as code                                    | Defining networks and servers in files that tools build automatically and repeatably.                               |
| <b>ICS</b>   | Industrial control system                                 | The general term for computers that run physical processes; SCADA is one kind.                                      |
| <b>ID</b>    | Identifier or identification                              | A name or number that uniquely labels a user, device, session, or record.                                           |
| <b>IDS</b>   | Intrusion detection system                                | Watches a copy of the traffic and alerts on attacks; cannot block them.                                             |
| <b>IKE</b>   | Internet Key Exchange                                     | Negotiates the keys and security associations for IPsec; UDP 500, and 4500 through NAT.                             |
| <b>IMAP</b>  | Internet Message Access Protocol                          | Reads mail that stays on the server, synced across devices; TCP 143, secure 993.                                    |
| <b>IMAPS</b> | IMAP Secure                                               | IMAP over TLS on TCP 993.                                                                                           |
| <b>iOS</b>   | iPhone operating system                                   | Apple's mobile operating system for iPhone.                                                                         |
| <b>IoT</b>   | Internet of Things                                        | Networked devices such as cameras, sensors, thermostats, and smart TVs.                                             |
| <b>IP</b>    | Internet Protocol                                         | The Layer 3 protocol that addresses and routes packets between networks.                                            |
| <b>IPS</b>   | Intrusion prevention system                               | Sits inline and blocks attacks as they pass.                                                                        |
| <b>IPsec</b> | Internet Protocol Security                                | The suite that encrypts and authenticates IP packets for VPNs.                                                      |
| <b>ISAC</b>  | Information sharing and analysis center                   | An industry group where members share threat intelligence.                                                          |
| <b>IT</b>    | Information technology                                    | Computers, networks, and the people who run them.                                                                   |
| <b>KMS</b>   | Key management service                                    | A managed, usually cloud-hosted, service that creates, stores, rotates, and controls access to encryption keys.     |
| <b>LACP</b>  | Link Aggregation Control Protocol                         | Negotiates bundling several physical links into one logical link (802.1AX, formerly 802.3ad).                       |
| <b>LAN</b>   | Local area network                                        | One site's network: a building, floor, or campus that one organization owns and runs.                               |
| <b>LDAP</b>  | Lightweight Directory Access Protocol                     | Queries a directory such as Active Directory for users and groups; TCP 389, secure 636.                             |
| <b>LDAPS</b> | LDAP Secure                                               | LDAP over TLS on TCP 636.                                                                                           |
| <b>LTE</b>   | Long-Term Evolution                                       | 4G cellular data; the workhorse mobile broadband standard.                                                          |
| <b>MAC</b>   | Media access control address, or mandatory access control | The Layer 2 hardware address of a network interface; in access control, the model where the system enforces labels. |
| <b>MD5</b>   | Message Digest 5                                          | A 128-bit hash that is broken: collisions can be manufactured; recognize, never recommend.                          |
| <b>MDM</b>   | Mobile device management                                  | Software that enrolls phones and tablets and enforces policy: passcodes, encryption, apps, remote wipe.             |
| <b>MFA</b>   | Multi-factor authentication                               | Two or more different kinds of proof: something you know, have, are, or where you are.                              |
| <b>MIME</b>  | Multipurpose Internet Mail Extensions                     | The standard that lets email carry attachments and non-text content.                                                |
| <b>MOA</b>   | Memorandum of agreement                                   | A more formal, sometimes binding, statement of what parties agree to do.                                            |
| <b>MOU</b>   | Memorandum of understanding                               | A non-binding statement of intent and roles between parties.                                                        |
| <b>MPLS</b>  | Multiprotocol Label Switching                             | A provider WAN that forwards by short labels instead of IP lookups, with traffic engineering and QoS.               |
| <b>ms</b>    | Millisecond                                               | One thousandth of a second; latency and response times.                                                             |
| <b>MSA</b>   | Master service agreement                                  | The umbrella contract covering a whole vendor relationship; individual jobs hang off it.                            |
| <b>MTBF</b>  | Mean time between failures                                | The average running time before a component fails; a reliability measure.                                           |
| <b>MTTR</b>  | Mean time to repair                                       | The average time to fix a failure and restore service.                                                              |

| ACRONYM        | STANDS FOR                                        | MEANING                                                                                                                                  |
|----------------|---------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NAC</b>     | Network access control                            | Checks a device's identity and health before letting it onto the network.                                                                |
| <b>NAT-T</b>   | NAT traversal                                     | Wraps IPsec in UDP 4500 so it can pass through address translation.                                                                      |
| <b>NDA</b>     | Non-disclosure agreement                          | A contract that keeps shared information confidential.                                                                                   |
| <b>NGFW</b>    | Next-generation firewall                          | A firewall that identifies applications and users, and includes intrusion prevention.                                                    |
| <b>NTP</b>     | Network Time Protocol                             | Synchronizes clocks across the network (UDP 123); wrong time breaks Kerberos, certificates, and logs.                                    |
| <b>NTS</b>     | Network Time Security                             | Authentication and integrity for NTP so time cannot be spoofed.                                                                          |
| <b>OAuth</b>   | Open Authorization                                | Lets a user grant an application limited access to their account on another service without sharing the password.                        |
| <b>OCSP</b>    | Online Certificate Status Protocol                | A real-time query to the CA asking whether one certificate is revoked.                                                                   |
| <b>OS</b>      | Operating system                                  | The software that manages hardware and runs applications: Windows, macOS, Linux, iOS, Android.                                           |
| <b>OSINT</b>   | Open-source intelligence                          | Information gathered from public sources: websites, social media, records, DNS.                                                          |
| <b>P7B</b>     | PKCS #7 bundle                                    | A file holding a certificate chain with no private key.                                                                                  |
| <b>PBKDF2</b>  | Password-Based Key Derivation Function 2          | Stretches a password with many hash rounds so guessing is slow.                                                                          |
| <b>PEAP</b>    | Protected EAP                                     | A server certificate creates a TLS tunnel and the user's password is checked inside it.                                                  |
| <b>PEM</b>     | Privacy Enhanced Mail (format)                    | The Base64 text format for certificates and keys, with BEGIN and END lines.                                                              |
| <b>PFX</b>     | Personal Information Exchange                     | A password-protected bundle holding a certificate and its private key (also .p12).                                                       |
| <b>PIN</b>     | Personal identification number                    | A short numeric secret, a something-you-know factor.                                                                                     |
| <b>PKI</b>     | Public key infrastructure                         | The system of certificate authorities, certificates, and revocation that makes public keys trustworthy.                                  |
| <b>POP3</b>    | Post Office Protocol version 3                    | Downloads mail to one device and usually deletes it from the server; TCP 110, secure 995.                                                |
| <b>POP3S</b>   | POP3 Secure                                       | POP3 over TLS on TCP 995.                                                                                                                |
| <b>PSK</b>     | Pre-shared key                                    | One shared passphrase for everyone on a Wi-Fi network (Personal mode).                                                                   |
| <b>RA</b>      | Registration authority                            | The part of a PKI that verifies identities before the CA signs.                                                                          |
| <b>RADIUS</b>  | Remote Authentication Dial-In User Service        | The AAA server behind Wi-Fi Enterprise, VPNs, and 802.1X; UDP 1812 and 1813.                                                             |
| <b>RAID</b>    | Redundant array of independent disks              | Combining disks for speed, capacity, or fault tolerance: 0 stripe, 1 mirror, 5 stripe with parity, 6 double parity, 10 mirrored stripes. |
| <b>RAM</b>     | Random-access memory                              | The working memory that holds running programs and data; lost at power off.                                                              |
| <b>RAT</b>     | Remote access trojan                              | Malware that opens a back door so an attacker can control the machine.                                                                   |
| <b>RBAC</b>    | Role-based access control                         | Permissions are assigned to roles, and users get roles.                                                                                  |
| <b>RC4</b>     | Rivest Cipher 4                                   | A fast stream cipher used in WEP and old TLS; broken and deprecated.                                                                     |
| <b>RDP</b>     | Remote Desktop Protocol                           | Microsoft's remote graphical desktop on TCP 3389.                                                                                        |
| <b>RFID</b>    | Radio-frequency identification                    | Tags read by radio for badges, inventory, and asset tracking.                                                                            |
| <b>RPO</b>     | Recovery point objective                          | The maximum acceptable data loss, measured in time.                                                                                      |
| <b>RSA</b>     | Rivest, Shamir, Adleman                           | The classic public-key algorithm for encryption and digital signatures.                                                                  |
| <b>RT0</b>     | Recovery time objective                           | The maximum acceptable time to restore a service after failure.                                                                          |
| <b>RTOS</b>    | Real-time operating system                        | An operating system that guarantees responses within strict time limits, used in embedded and control devices.                           |
| <b>RTP</b>     | Real-time Transport Protocol                      | Carries the actual voice and video packets of a call, over UDP.                                                                          |
| <b>SaaS</b>    | Software as a service                             | Complete applications delivered over the web, such as email and office suites.                                                           |
| <b>SAE</b>     | Simultaneous authentication of equals             | The WPA3 Personal handshake that resists offline password guessing.                                                                      |
| <b>SAHL</b>    | Security Assertion Markup Language                | An XML standard for passing authentication between an identity provider and a web application (enterprise SSO).                          |
| <b>SAN</b>     | Subject alternative name, or storage area network | On a certificate, the list of hostnames it covers; in infrastructure, a dedicated block-storage network.                                 |
| <b>SASE</b>    | Secure access service edge                        | SD-WAN networking plus cloud-delivered security (firewall, web gateway, ZTNA, CASB) as one service.                                      |
| <b>SCADA</b>   | Supervisory control and data acquisition          | Systems that monitor and control industrial processes such as power, water, and manufacturing.                                           |
| <b>SCAP</b>    | Security Content Automation Protocol              | Standard formats that let tools check systems against security benchmarks automatically.                                                 |
| <b>SD-WAN</b>  | Software-defined wide area network                | Steers traffic across several cheap links (broadband, LTE, MPLS) by policy from a central controller.                                    |
| <b>SDLC</b>    | Software development life cycle                   | The phases of building software: plan, design, code, test, deploy, maintain.                                                             |
| <b>SDN</b>     | Software-defined networking                       | Separates the control plane (decisions) from the data plane (forwarding) and centralizes control.                                        |
| <b>SFTP</b>    | SSH File Transfer Protocol                        | File transfer inside an SSH session, TCP 22.                                                                                             |
| <b>SHA</b>     | Secure Hash Algorithm                             | The family of hash functions: SHA-1 (deprecated), SHA-2 (SHA-256, the standard), SHA-3.                                                  |
| <b>SHA-1</b>   | Secure Hash Algorithm 1                           | A 160-bit hash, deprecated because collisions have been found.                                                                           |
| <b>SHA-2</b>   | Secure Hash Algorithm 2                           | The current hash family, including SHA-256 and SHA-512.                                                                                  |
| <b>SHA-256</b> | Secure Hash Algorithm 256-bit                     | The standard hash today: a 256-bit fingerprint of any input.                                                                             |
| <b>SHA-3</b>   | Secure Hash Algorithm 3                           | A newer hash standard with a different internal design from SHA-2.                                                                       |

| ACRONYM        | STANDS FOR                                            | MEANING                                                                                                                               |
|----------------|-------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| <b>SIEM</b>    | Security information and event management             | Collects logs from everything, correlates them, and raises alerts.                                                                    |
| <b>SIP</b>     | Session Initiation Protocol                           | Sets up and tears down voice and video calls; port 5060, or 5061 with TLS.                                                            |
| <b>SLA</b>     | Service level agreement                               | The contract stating measurable service commitments, such as 99.9% uptime.                                                            |
| <b>SLE</b>     | Single loss expectancy                                | The cost of one occurrence of a risk: asset value times exposure factor.                                                              |
| <b>SMB</b>     | Server Message Block                                  | Windows file and printer sharing on TCP 445.                                                                                          |
| <b>SMS</b>     | Short Message Service                                 | Text messages; used for one-time codes and also a phishing channel (smishing).                                                        |
| <b>SMTP</b>    | Simple Mail Transfer Protocol                         | Sends email between servers on TCP 25; clients submit on 587 with TLS.                                                                |
| <b>SMTPS</b>   | SMTP Secure                                           | SMTP with TLS, port 465 (implicit) or 587 with STARTTLS.                                                                              |
| <b>SNMP</b>    | Simple Network Management Protocol                    | Polls and receives alerts from network devices (UDP 161 polls, 162 traps).                                                            |
| <b>SOW</b>     | Statement of work                                     | Defines one specific piece of work: deliverables, timeline, and price.                                                                |
| <b>SPF</b>     | Sender Policy Framework                               | A DNS TXT record listing which servers may send mail for a domain.                                                                    |
| <b>SQL</b>     | Structured Query Language                             | The language used to query databases; also the name of the servers on TCP 1433 (Microsoft) and 3306 (MySQL).                          |
| <b>SRTP</b>    | Secure Real-time Transport Protocol                   | Encrypted RTP for voice and video.                                                                                                    |
| <b>SSH</b>     | Secure Shell                                          | Encrypted remote command-line access and file transfer on TCP 22; replaces Telnet and FTP.                                            |
| <b>SSID</b>    | Service set identifier                                | The Wi-Fi network name that access points broadcast and clients join.                                                                 |
| <b>SSL</b>     | Secure Sockets Layer                                  | The predecessor of TLS; every version is deprecated.                                                                                  |
| <b>SSO</b>     | Single sign-on                                        | Log in once and reach many systems without signing in again.                                                                          |
| <b>SSRF</b>    | Server-side request forgery                           | Makes the web server itself fetch a URL the attacker supplies, often reaching internal systems.                                       |
| <b>SY0-701</b> | CompTIA Security+ exam SY0-701                        | The current version of the Security+ certification exam.                                                                              |
| <b>TACACS+</b> | Terminal Access Controller Access-Control System Plus | Cisco's AAA protocol for device administration on TCP 49; encrypts the whole payload and separates authentication from authorization. |
| <b>TCP</b>     | Transmission Control Protocol                         | Reliable, ordered, connection-based transport: three-way handshake, acknowledgments, retransmission.                                  |
| <b>TFTP</b>    | Trivial File Transfer Protocol                        | Bare-bones UDP 69 file transfer with no login, used for firmware and config files.                                                    |
| <b>TKIP</b>    | Temporal Key Integrity Protocol                       | WPA's per-packet keying scheme; deprecated.                                                                                           |
| <b>TLS</b>     | Transport Layer Security                              | The encryption layer under HTTPS and most secure protocols; use 1.2 or 1.3.                                                           |
| <b>TOC</b>     | Time of check                                         | The moment a program verifies a condition; in a race condition, before it acts on it.                                                 |
| <b>TOU</b>     | Time of use                                           | The moment a program acts on a condition it checked earlier.                                                                          |
| <b>TPM</b>     | Trusted Platform Module                               | A security chip on the motherboard that stores keys and measurements; required for BitLocker and Windows 11.                          |
| <b>TV</b>      | Television                                            | A display or broadcast receiver; smart TVs are IoT devices.                                                                           |
| <b>UBA</b>     | User behavior analytics                               | Baselines what each user normally does and flags deviations.                                                                          |
| <b>UEFI</b>    | Unified Extensible Firmware Interface                 | Modern firmware that replaces BIOS: GPT disks, Secure Boot, mouse-driven setup.                                                       |
| <b>UPS</b>     | Uninterruptible power supply                          | A battery unit that keeps equipment running through a power cut and conditions the power.                                             |
| <b>URL</b>     | Uniform resource locator                              | A web address such as <a href="https://www.example.com/page">https://www.example.com/page</a> .                                       |
| <b>USB</b>     | Universal Serial Bus                                  | The standard port for peripherals, storage, and charging.                                                                             |
| <b>UTH</b>     | Unified threat management                             | One appliance bundling firewall, IDS/IPS, antivirus, content filtering, and VPN.                                                      |
| <b>VLAN</b>    | Virtual local area network                            | A logical LAN on a switch: ports in different VLANs are separate broadcast domains.                                                   |
| <b>VM</b>      | Virtual machine                                       | A complete computer running as software on a hypervisor.                                                                              |
| <b>VPN</b>     | Virtual private network                               | An encrypted tunnel across an untrusted network such as the internet.                                                                 |
| <b>WAF</b>     | Web application firewall                              | A firewall that understands HTTP and blocks attacks on web applications such as SQL injection and XSS.                                |
| <b>WAN</b>     | Wide area network                                     | Connects LANs across cities or countries, usually over links leased from a provider.                                                  |
| <b>WEP</b>     | Wired Equivalent Privacy                              | The original Wi-Fi encryption, broken in minutes; never use it.                                                                       |
| <b>Wi-Fi</b>   | Wireless fidelity                                     | The trade name for IEEE 802.11 wireless networking.                                                                                   |
| <b>WO</b>      | Work order                                            | A short authorization for one specific job.                                                                                           |
| <b>WPA</b>     | Wi-Fi Protected Access                                | The interim fix for WEP that used TKIP; deprecated.                                                                                   |
| <b>WPA2</b>    | Wi-Fi Protected Access 2                              | Wi-Fi security using AES with CCMP; still common and acceptable.                                                                      |
| <b>WPA3</b>    | Wi-Fi Protected Access 3                              | The current Wi-Fi security standard: SAE in Personal mode, stronger encryption, protected management frames.                          |
| <b>XDR</b>     | Extended detection and response                       | EDR extended across endpoints, network, cloud, and email into one correlated view.                                                    |
| <b>XML</b>     | Extensible Markup Language                            | A text format for structured data, used by SAML, HL7 version 3, and many configuration files.                                         |
| <b>XSS</b>     | Cross-site scripting                                  | An attacker's script runs in other users' browsers because a site echoes untrusted input.                                             |